SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no		**Name of the Student**	

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action. **Signature of Student**

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)
Key points: malware types (virus, worm, trojan, ransomware, spyware); phishing via deceptive emails, links or sites to steal credentials; DoS from a single source versus DDoS from a botnet; preventive measures such as antivirus, user awareness training, rate limiting, firewalls and CDN or traffic scrubbing.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)
Key points: the attacker intercepts and may alter communication between two parties; techniques include ARP poisoning, rogue Wi-Fi access points, DNS spoofing and session hijacking; countermeasures include HTTPS/TLS, VPN, certificate validation, HSTS and dynamic ARP inspection.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)
Key points: spoofing is forging identity (IP, MAC, email or DNS spoofing); sniffing is passively capturing packets (Wireshark, tcpdump) and mainly exposes unencrypted data; prevention includes encryption, switched networks, port security and anti-spoofing filters.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)
Key points: the process is asset identification, scanning (Nessus, OpenVAS), analysis, risk rating and reporting; the report contains an executive summary, scope and methodology, findings with CVE IDs, CVSS severity scores, evidence, risk impact and prioritized remediation recommendations; also mention how it differs from penetration testing.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)
Key points: OSINT draws on public sources such as WHOIS, Shodan, social media, news, forums, code repositories and the CVE/NVD databases; also cover commercial and internal sources (logs, honeypots) and collection techniques such as passive collection, web scraping and DNS or domain lookups; mention legal and ethical considerations.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)
Key points: IoCs are artifacts such as file hashes, malicious IPs, domains, URLs, registry keys and unusual network traffic; threat feeds (open-source or commercial, in formats like STIX/TAXII) deliver them for SIEM or firewall blocking and faster detection; limitations include false positives, stale data and the need for context.

Answers

1. Types of Network Attacks

Malware

Malware is malicious software designed to damage systems, steal information, or gain unauthorized access.

Types:

- **Virus:** Attaches itself to files and spreads when executed.
- **Worm:** Spreads automatically across networks.
- **Trojan Horse:** Appears to be legitimate software but performs malicious activities.
- **Ransomware:** Encrypts files and demands money.
- **Spyware:** Secretly monitors user activities.

Example: WannaCry ransomware encrypted files on computers worldwide.

Prevention: Install antivirus software and regularly update the operating system.

Phishing

Phishing is a cyberattack in which attackers use fake emails, messages, or websites to steal passwords and banking details.

Example: A fake bank email asks users to click a link and enter their login credentials.

Prevention: Avoid suspicious links, verify the sender's identity, and provide user awareness training.

Denial of Service (DoS)

A DoS attack makes a website or network service unavailable by overwhelming it with excessive requests from a single source.

Example: An attacker sends numerous requests to a college website, making it unavailable.

Prevention: Use firewalls, rate limiting, and traffic filtering.

Distributed Denial of Service (DDoS)

A DDoS attack uses multiple compromised devices, called a botnet, to flood a target with traffic.

Example: A botnet floods an online shopping website, preventing customers from accessing it.

Prevention: Use CDN services, DDoS protection, and traffic-scrubbing systems.

Difference: DoS generally uses a single source, whereas DDoS uses multiple sources and is more difficult to block.

Conclusion: Antivirus software, security awareness, firewalls, and DDoS protection help reduce network attacks.

2. Man-in-the-Middle (MitM) Attack

A Man-in-the-Middle (MitM) attack occurs when an attacker secretly intercepts communication between two parties and may read or modify the exchanged information.

Working of MitM Attack

1. Two parties communicate over a network.
2. The attacker secretly positions themselves between them.
3. The attacker intercepts the communication.
4. The attacker may read or modify unprotected information.
5. Sensitive information, such as passwords and banking details, may be stolen.

Example: An attacker creates a fake public Wi-Fi hotspot and attempts to intercept users' unprotected communication.

Techniques Used

1. **ARP Poisoning:** The attacker sends forged ARP messages to redirect network traffic.
2. **Rogue Wi-Fi Access Point:** The attacker creates a fake Wi-Fi hotspot to trick users.
3. **DNS Spoofing:** The attacker provides false DNS information to redirect users to malicious websites.

4. **Session Hijacking:** The attacker steals or misuses a valid session token to access an account.

Countermeasures

1. **HTTPS/TLS:** Encrypts communication between users and websites.
2. **VPN:** Protects network traffic through an encrypted tunnel.
3. **Certificate Validation:** Ensures the website's certificate is valid.
4. **HSTS:** Helps ensure browsers use HTTPS for supported websites.
5. **Dynamic ARP Inspection:** Helps prevent ARP spoofing.
6. **Secure Wi-Fi:** Use trusted wireless networks and strong security settings.
7. **Multi-Factor Authentication:** Adds another layer of account protection.

Conclusion: Encryption, secure networks, certificate validation, and proper authentication help prevent MitM attacks.

3. Spoofing and Sniffing

Spoofing

Spoofing is a cyberattack in which an attacker falsifies an identity or address to impersonate a trusted user, device, or system.

Types of Spoofing

1. **IP Spoofing:** The attacker forges the source IP address in network packets.
2. **MAC Spoofing:** The attacker changes a device's MAC address to impersonate another device.
3. **Email Spoofing:** The attacker forges an email sender address to make a message appear trustworthy.
4. **DNS Spoofing:** The attacker manipulates DNS information to redirect users to malicious websites.

Example: An attacker sends an email that appears to come from a bank to steal passwords.

Prevention: Use SPF, DKIM, and DMARC email authentication protocols and network anti-spoofing filters.

Sniffing

Sniffing is the process of capturing and examining network packets to observe communication between devices.

Tools: Wireshark and tcpdump.

Example: An attacker captures unencrypted traffic on an insecure public Wi-Fi network.

Types of Sniffing

1. **Passive Sniffing:** The attacker observes network traffic without modifying it.

2. **Active Sniffing:** The attacker manipulates or influences network traffic to capture packets, particularly on switched networks.

Difference Between Spoofing and Sniffing

Spoofing	**Sniffing**
Falsifies identity or address.	Captures and examines network packets.
Used to impersonate a trusted system.	Used to monitor network communication.
May involve modifying packet headers.	Often involves observing traffic.
Example: Email spoofing.	Example: Capturing unencrypted traffic.

Prevention of Sniffing

1. Use HTTPS/TLS encryption.

2. Use a VPN on untrusted networks.

3. Implement switch port security.

4. Monitor unusual network activity.

5. Use anti-spoofing filters.

6. Secure Wi-Fi networks with strong security settings.

Conclusion: Spoofing involves falsifying identity, whereas sniffing involves capturing network traffic. Encryption and proper network security help protect against both attacks.

4. Vulnerability Assessment

A Vulnerability Assessment (VA) is a systematic process of identifying, analyzing, and prioritizing security weaknesses in computer systems, networks, applications, and devices.

Its main purpose is to identify vulnerabilities before attackers exploit them.

Steps in Vulnerability Assessment

1. Asset Identification: Identify the systems, servers, applications, databases, and network devices to be assessed.

2. Define Scope: Determine which systems and IP addresses are included and obtain proper authorization.

3. Vulnerability Scanning: Use tools such as Nessus, OpenVAS, and Nmap to identify known security weaknesses.

4. Vulnerability Analysis: Examine scan results to identify outdated software, misconfigurations, and missing security patches.

5. Risk Assessment: Evaluate vulnerabilities based on severity, likelihood of exploitation, and potential impact. CVSS scores help measure severity.

6. Prioritization: Prioritize critical and high-risk vulnerabilities for remediation.

7. Remediation: Fix vulnerabilities by installing patches, changing configurations, and strengthening access controls.

8. Reassessment: Perform another scan to verify that the vulnerabilities have been fixed.

Contents of a Vulnerability Assessment Report

1. **Executive Summary:** Overview of the assessment and major findings.
2. **Scope and Objectives:** Lists the systems and objectives covered.
3. **Methodology:** Describes the tools and assessment procedures.

4. **Vulnerability Details:** Lists identified vulnerabilities and supporting evidence.

5. **CVE IDs:** Includes Common Vulnerabilities and Exposures identifiers where applicable.

6. **CVSS Severity Scores:** Classifies vulnerabilities as Critical, High, Medium, or Low.

7. **Risk and Impact:** Explains the possible effects on confidentiality, integrity, and availability.

8. **Remediation Recommendations:** Provides steps to fix identified vulnerabilities.

9. **Conclusion:** Summarizes findings and future security improvements.

Difference Between Vulnerability Assessment and Penetration Testing

Vulnerability Assessment	**Penetration Testing**
Identifies security weaknesses.	Attempts to exploit weaknesses under controlled conditions.
Often uses automated scanning tools.	Uses manual and automated testing.
Prioritizes vulnerabilities for remediation.	Demonstrates the potential impact of vulnerabilities.
Produces a list of weaknesses.	Produces evidence of successful or attempted exploitation.

Conclusion: Vulnerability assessment helps organizations identify weaknesses and reduce security risks through scanning, analysis, prioritization, and remediation.

5. Open-Source Intelligence (OSINT)

Open-Source Intelligence (OSINT) is the process of collecting, analyzing, and interpreting information from publicly available sources to produce useful intelligence.

In cybersecurity, OSINT helps identify potential threats, malicious domains, suspicious IP addresses, and security risks.

Common Threat Data Sources

1. WHOIS Records: Provide domain registration details, such as registration dates and registrar information.

2. Shodan: Helps identify internet-connected devices and exposed network services.

3. Social Media: Provides information about suspicious accounts, impersonation, scams, and publicly shared threat indicators.

4. News Websites: Provide information about cyberattacks, data breaches, and emerging security threats.

5. Online Forums: May contain discussions about emerging threats and attacker techniques.

6. Code Repositories: Public repositories may reveal exposed credentials, vulnerable code, or malware samples.

7. CVE and NVD Databases: Provide information about publicly disclosed vulnerabilities and their severity.

8. Commercial Threat Intelligence Feeds: Provide threat indicators, malicious IP addresses, suspicious domains, and information about attacker activities.

9. Internal Security Sources: System logs, firewall logs, SIEM alerts, and honeypots provide information about suspicious activity within an organization.

Techniques Used to Collect Threat Data

1. Passive Collection: Collect information from public websites, search engines, public DNS records, and published security reports.

2. Web Scraping: Automatically extract relevant information from permitted public webpages.

3. DNS and Domain Lookups: Examine DNS records and domain information to identify suspicious domains.

4. IP Address Analysis: Investigate IP addresses using threat intelligence services to identify potentially malicious activity.

5. Search Engine Research: Use search engines and specialized queries to discover public security reports and exposed information.

6. Threat Feed Analysis: Collect and analyze indicators from public or commercial threat intelligence feeds.

7. Log Analysis: Examine firewall, server, and SIEM logs to identify suspicious connections and possible security incidents.

Legal and Ethical Considerations

1. Collect information lawfully.
2. Respect privacy and data protection laws.
3. Do not access systems without authorization.
4. Follow website terms of service.
5. Verify information using reliable sources.

Conclusion: OSINT is an important cybersecurity technique for gathering threat intelligence from public sources. Combining OSINT with internal logs and threat intelligence feeds helps organizations detect threats and improve security.

6. **Indicators of Compromise (IoCs)**

Indicators of Compromise (IoCs) are pieces of evidence that indicate a computer system or network may have been attacked or compromised. They help security teams detect malicious activities and investigate cyberattacks.

Types of IoCs

1. File Hashes:
A file hash is a unique value generated from a file. It helps identify known malicious files.

Example: SHA-256 hash of a malware file.

2. Malicious IP Addresses:
IP addresses associated with suspicious servers or attackers.

Example: An IP address communicating with a known command-and-control server.

3. Malicious Domains:
Domain names used for phishing, malware distribution, or command-and-control communication.

Example: A fake banking domain designed to steal login credentials.

4. Malicious URLs:
Web addresses that host malware or phishing pages.

Example: A fake login URL that collects passwords.

5. Registry Keys:
Suspicious Windows registry entries created by malware to maintain persistence or modify system settings.

6. Unusual Network Traffic:
Unexpected network connections, repeated communication with suspicious servers, or unusual data transfers.

How Threat Feeds Improve Security

Threat feeds provide regularly updated information about cyber threats, including malicious IP addresses, domains, file hashes, and attack techniques.

1. Faster Threat Detection:
Security teams can identify suspicious activities using known IoCs.

2. SIEM Integration:
Threat feeds can be integrated with Security Information and Event Management (SIEM) tools to detect threats by matching IoCs against collected logs.

3. Automatic Blocking:
Firewalls and other security tools can use threat intelligence to block known malicious IP addresses and domains.

4. Early Warning:
Threat feeds inform organizations about emerging threats before they cause serious damage.

5. Incident Response:
IoCs help investigators identify affected systems and understand how an attack occurred.

6. Types of Threat Feeds:

- **Open-source feeds:** Freely available threat information from public security sources.
- **Commercial feeds:** Paid services that provide specialized threat intelligence.

7. STIX and TAXII:
STIX is a standardized language for representing threat intelligence, while TAXII is a protocol for exchanging threat intelligence between systems.

Conclusion: IoCs help identify signs of cyberattacks, while threat feeds provide updated threat information. Integrating them with SIEM systems and firewalls improves threat detection, incident response, and overall network security.